

Proyecto 6 - Observabilidad y Seguridad en Kubernetes

Monitoreo, alertamiento, evaluación CIS
y evidencia para ISO/IEC 27001:2022

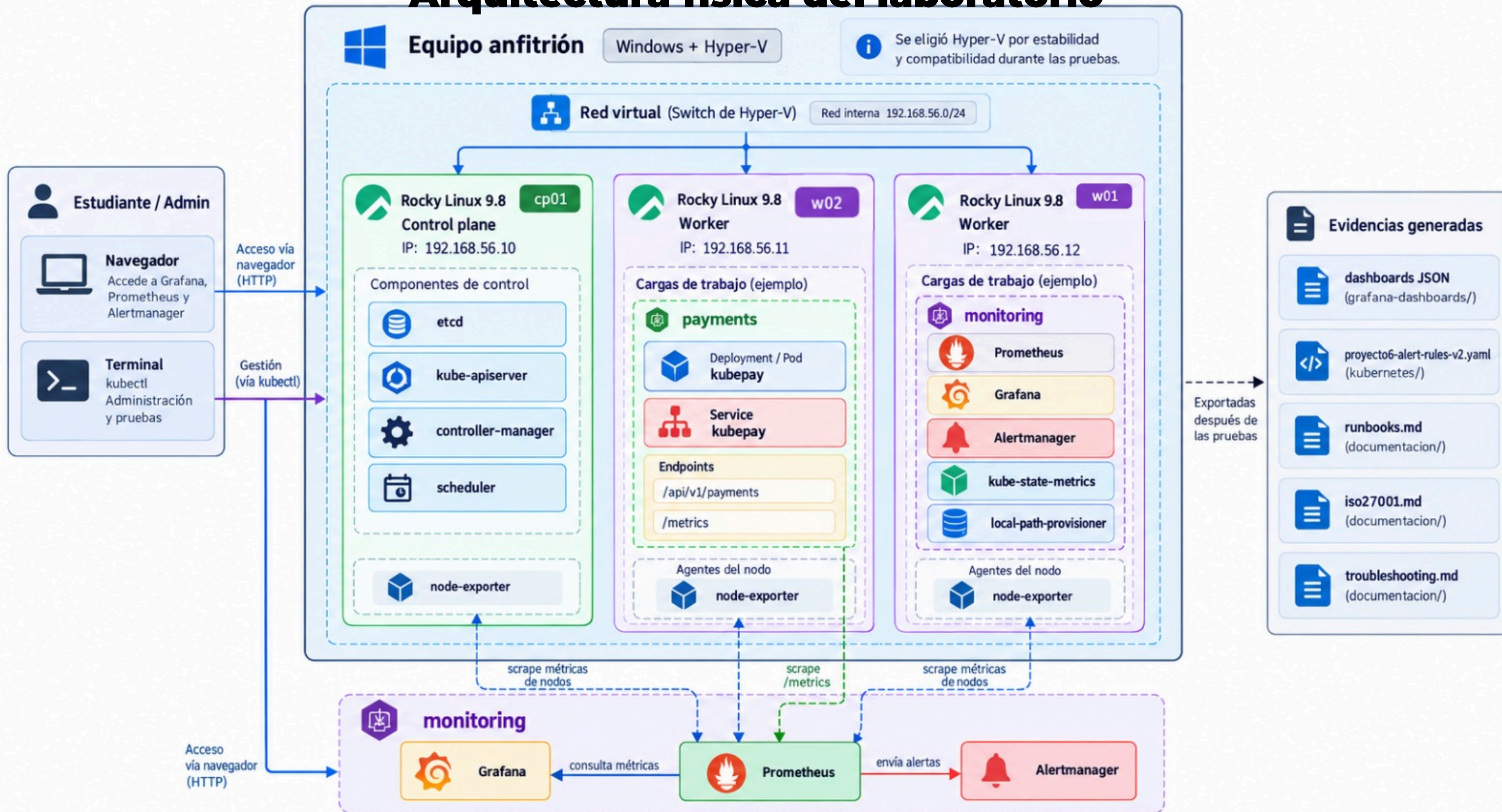


Kubernetes • Prometheus • Grafana • Alertmanager • kube-bench

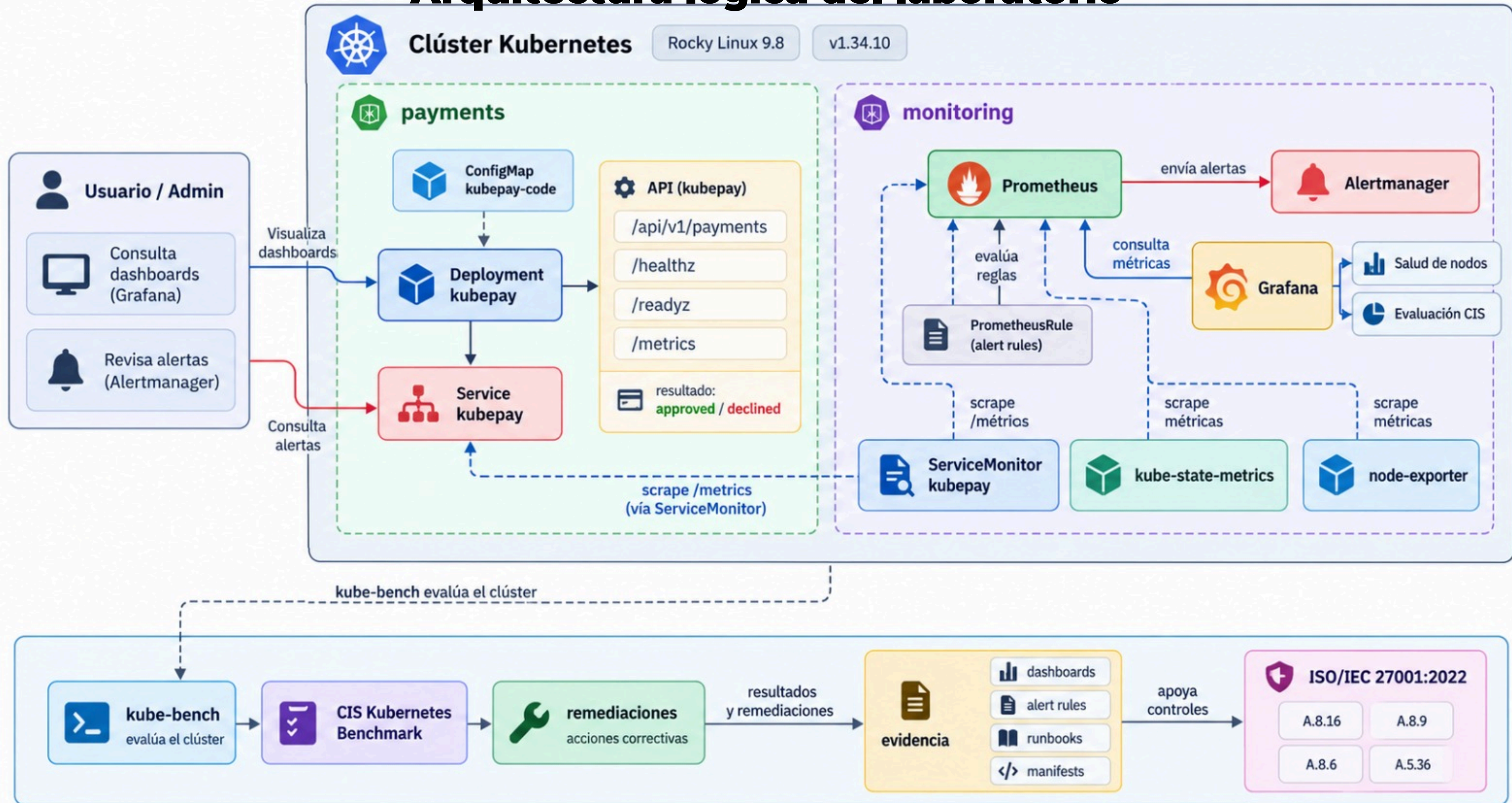
Integrantes

- María Fernanda Martínez Jiménez
- Angel Jacob Argueta Bravo

Arquitectura física del laboratorio



Arquitectura lógica del laboratorio



KubePay: Carga de Trabajo y Telemetría

API representativa de pagos para evaluación operativa y criterio de auditoría forense.

⚙️ Lógica Funcional de Pagos:

- ✓ **Aprobado:** Montos de \$0.01 a \$10,000 (MXN, USD, EUR)
- ✗ **Declinado:** Montos mayores a \$10,000, valores en cero o negativos, o monedas no autorizadas.

Carga Representativa

API simulada de procesamiento transaccional.

Tráfico real con transacciones aprobadas y declinadas.

Escenario base para validar observabilidad y saturación.



Instrumentación HTTP

GET /healthz & /readyz (salud del pod).

POST /api/v1/payments (tráfico).

GET /metrics (kubepay_payments_total, tasas y latencias PromQL).



Métrica vs. Log

Métrica: Detecta anomalías, tendencias y dispara alertas.

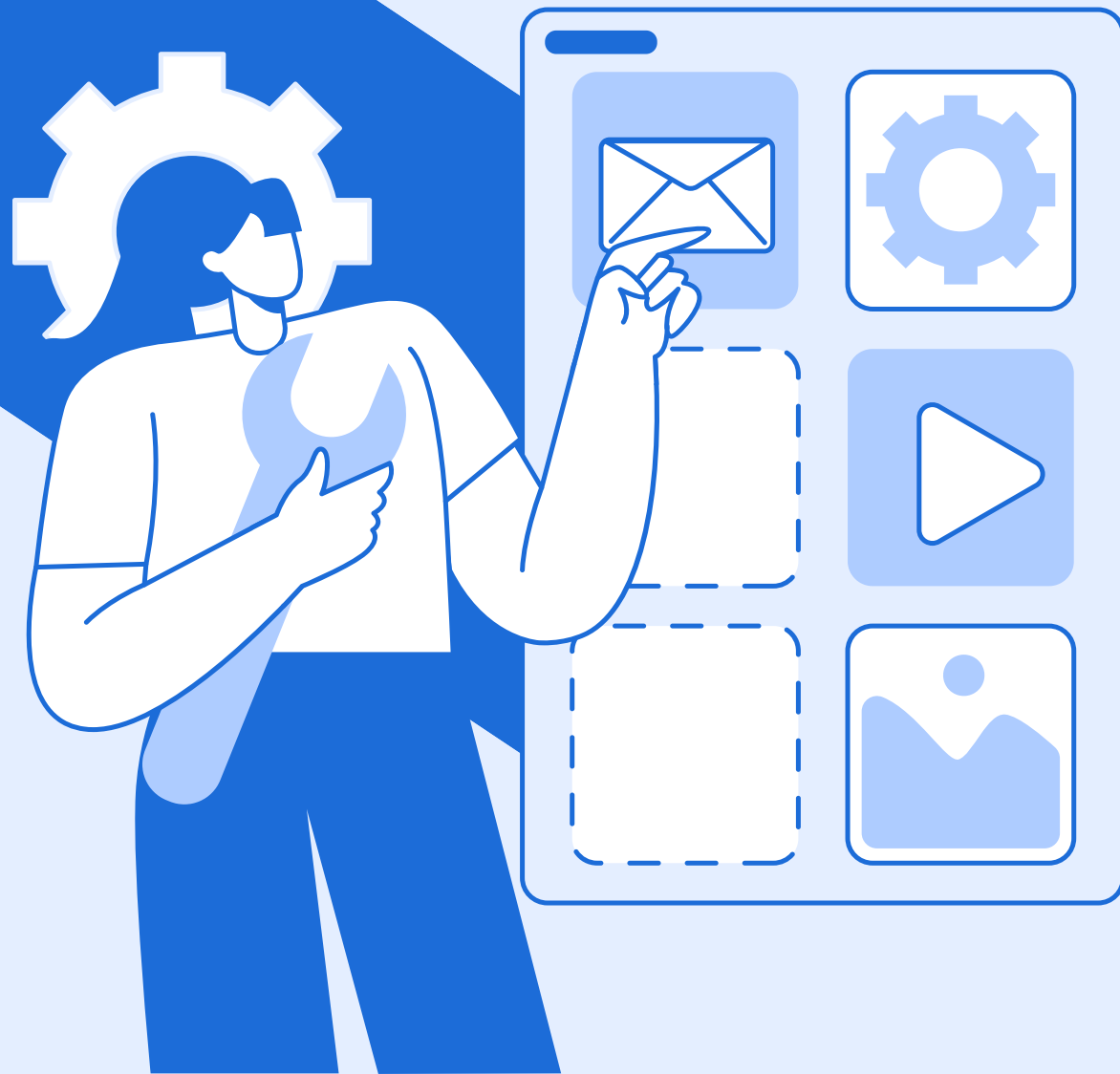
Log / Evento: Aporta el contexto, la causa raíz y el actor.

Una métrica no basta para una reconstrucción forense.



Alineación con ISO/IEC 27001:2022

Mapeo directo entre la telemetría del clúster y los controles de seguridad de la información.



1

A.8.16 - Monitoreo de actividades

Supervisión continua de telemetría y comportamiento operativo mediante Prometheus, Grafana y Alertmanager.

2

A.8.9 - Gestión de configuración

Manifiestos declarativos y hardening del plano de control mitigando configuraciones inseguras

3

A.8.6 - Gestión de capacidad

Alertamiento preventivo ante saturación de CPU, memoria y cuotas de almacenamiento para evitar denegación de servicio.

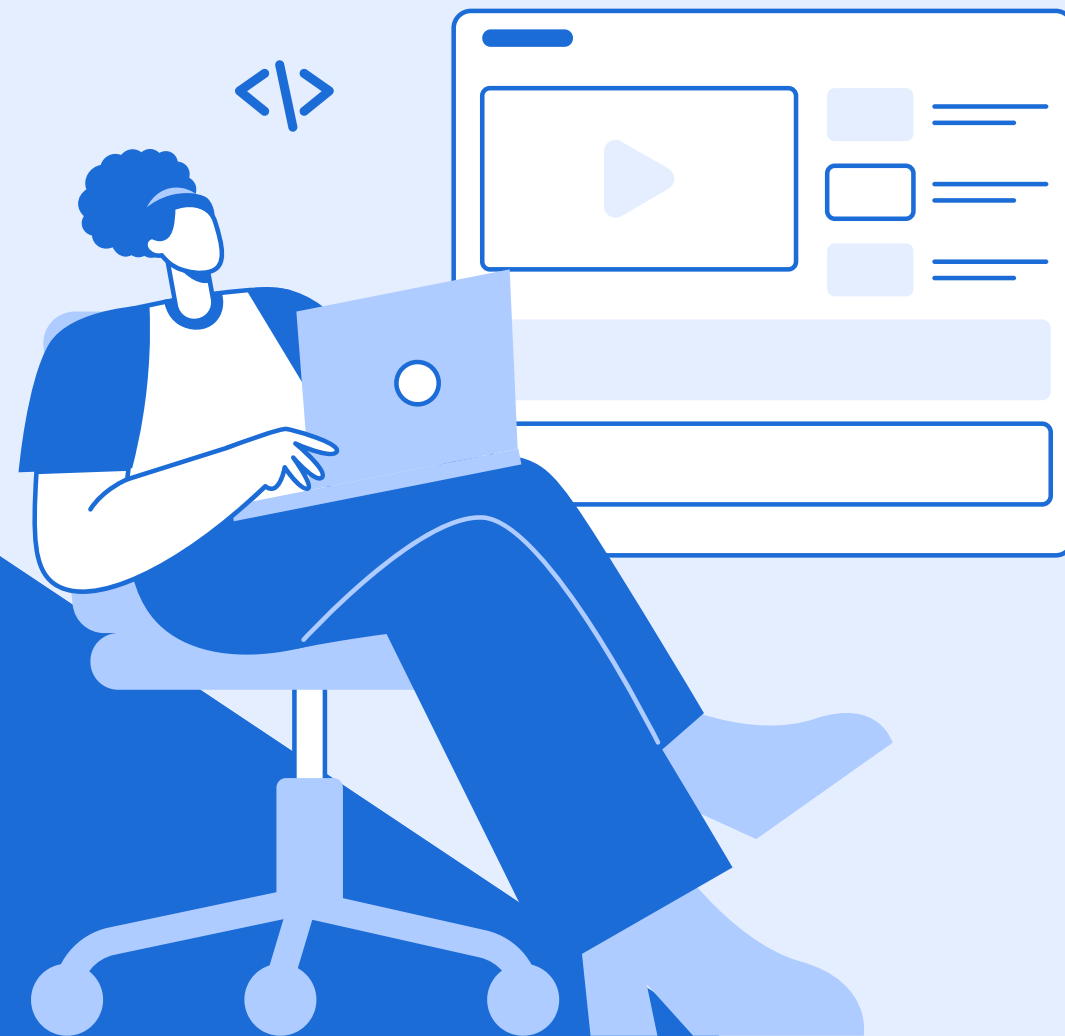
4

A.5.36 - Cumplimiento de políticas y normas

Auditoría automatizada y reproducible con kube-bench para evidenciar apego al estándar CIS Benchmark.

Resultados CIS y Hardening

Evaluación mediante kube-bench y remediación activa en el clúster.



Evaluación Before / After

Punto destacado (Impacto):
50% de Reducción en FAIL

Resumen de métricas:
PASS: de 85 a 92
FAIL: de 14 a 7
WARN: 52 (supervisados)

Verificación
Postura validada mediante re-ejecución automatizada de kube-bench como Job.

Remediaciones y Riesgo Residual

5 Acciones correctivas aplicadas:

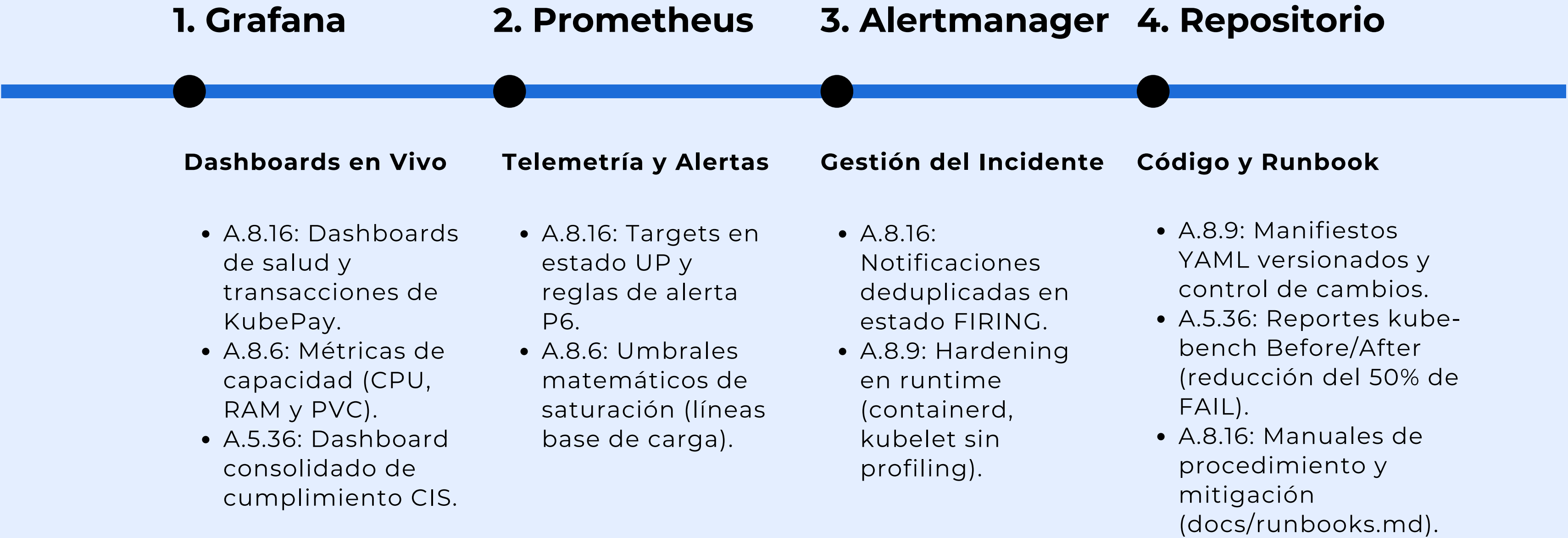
- Permisos restrictivos (600) en kubelet.service.
- Permisos restrictivos (600) en config.yaml de kubelet.
- Parámetro --profiling=false en kube-apiserver.
- Parámetro --profiling=false en kube-controller-manager.
- Parámetro --profiling=false en kube-scheduler.

Riesgo residual transparente:

7 FAIL diferidos intencionalmente (retención de logs de auditoría del API Server y ownership de datos de etcd) para preservar la estabilidad operativa del entorno.

Cadena de Evidencia ante Auditoría

"Si un auditor solicita evidencia de algún control, ¿qué le mostramos y desde dónde?"



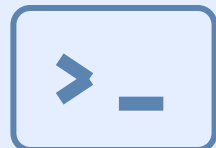
Demostración Técnica y Validación

Flujo estructurado en vivo para validar salud, telemetría y ciclo de alerta ante incidentes.

1

Estado Saludable

Verificación en terminal mediante `kubectl get nodes` y `kubectl get pods -A`. Nodos `cp01`, `w01` y `w02` en estado Ready previo a la inyección de tráfico.



2

Observabilidad Activa

Recorrido ágil por dashboards en Grafana (Salud de Nodos, KubePay y Postura CIS). Confirmación de targets de infraestructura y aplicación en estado UP en Prometheus.



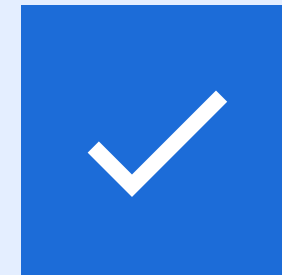
3

Simulación de Incidente

Disparo de alerta en vivo: `P6KubePayHighDeclineRate`. Transición a estado FIRING, recepción en Alertmanager y recuperación sin intervención destructiva.



Conclusiones y Lecciones Aprendidas



Trazabilidad de Extremo a Extremo

Cadena verificable que conecta arquitectura, recolección con Prometheus Operator, tableros en Grafana y Alertmanager.



Reducción Efectiva de Brechas

Disminución del 50% en hallazgos FAIL mediante hardening en nodos y plano de control bajo CIS Benchmark.



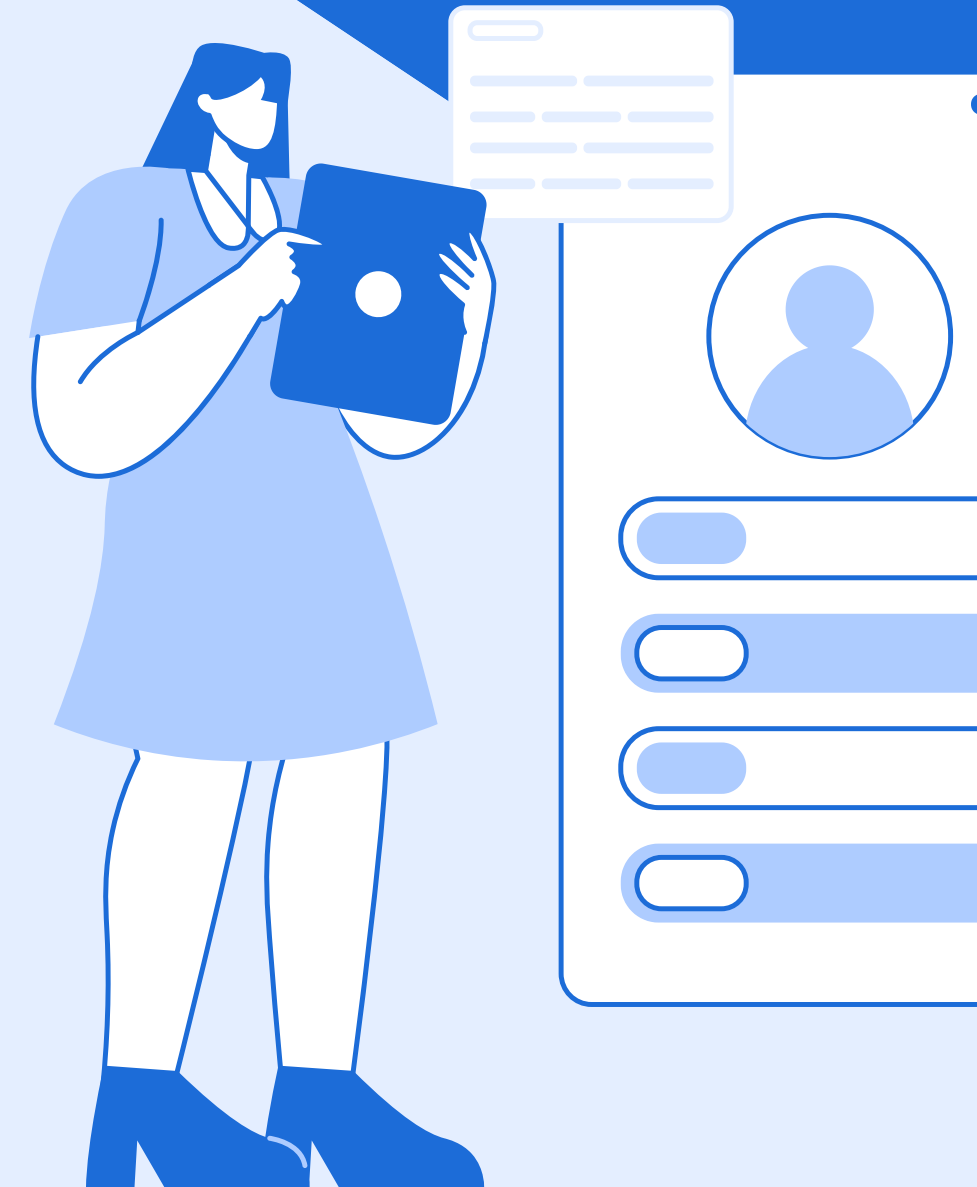
Criterio Técnico y Postura Forense

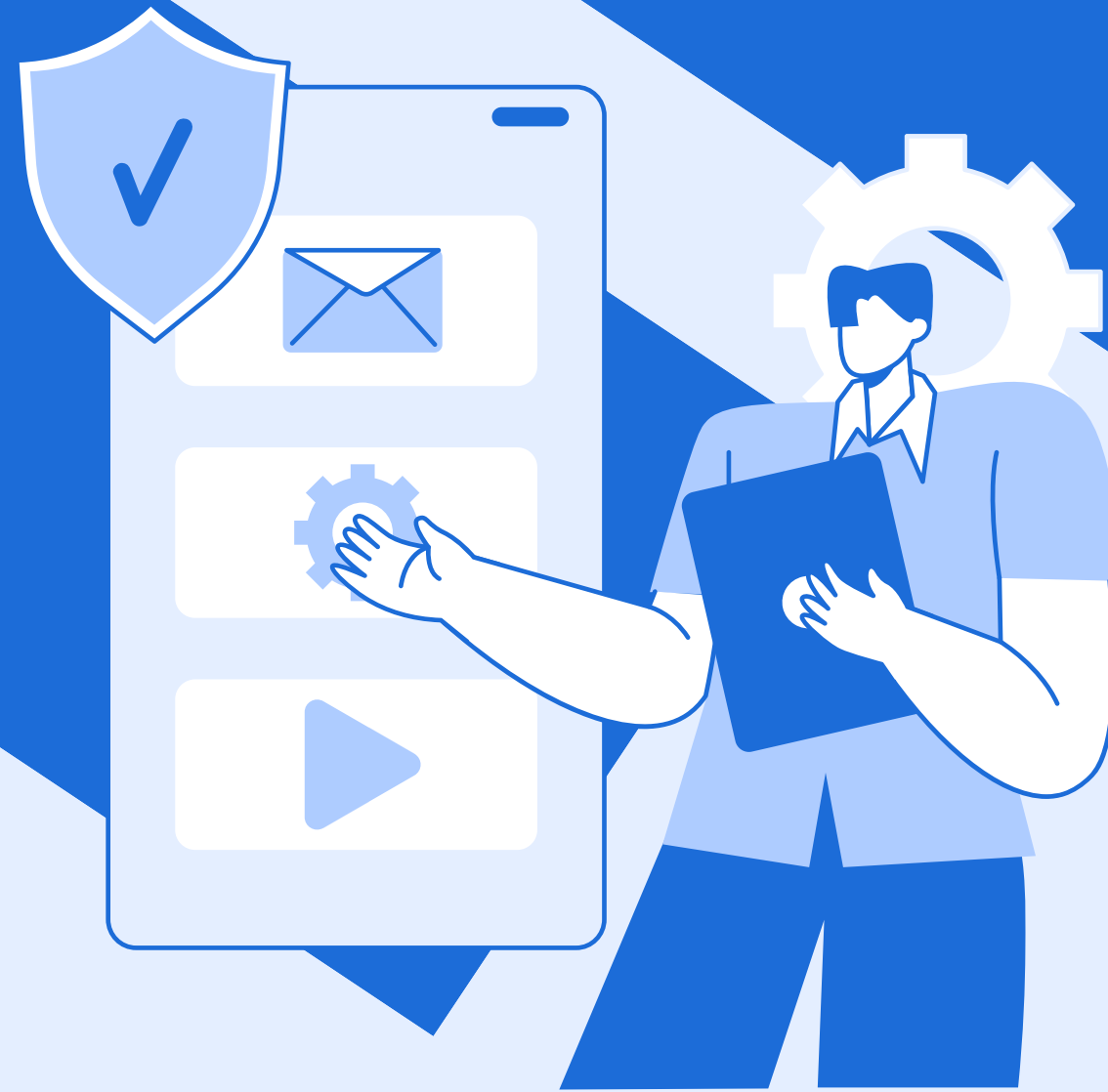
Delimitación clara entre la telemetría numérica (tendencia y alerta) y la necesidad de logs para causa raíz.



Alineación con ISO/IEC 27001

Evidencia auditable mediante artefactos reproducibles: manifiestos declarativos, tableros JSON y runbooks estandarizados.





Gracias